Vulnerability Assessment Report

Target Website: http://testphp.vulnweb.com
Intern: Jay Sutar
Domain: Cyber Security
Tool Used: Nmap, OWASP ZAP

---

1. Introduction

This report presents the results of a vulnerability assessment conducted on the publicly available test website *testphp.vulnweb.com*.

The purpose of this assessment was to identify security weaknesses and classify associated risks.

---

2. Objective

- Identify open ports and exposed services
- Detect common web application vulnerabilities
- Classify risks (High / Medium / Low)
- Provide remediation recommendations

---

3. Scope

The assessment was conducted only on a publicly available test website designed for security testing purposes.

No unauthorized systems were scanned.

---

4. Tools Used

- Nmap (Port Scanning & Service Detection)
- OWASP ZAP (Web Vulnerability Scanning)

---

5. Methodology

1. Performed port scanning using Nmap.
2. Identified open services and server version details.
3. Conducted automated web application scan using OWASP ZAP.
4. Analyzed alerts and classified risks.

---

6. Findings

🔍 Finding 1: Open HTTP Port (80)

Tool Used: Nmap
Risk Level: Medium

Description:
Port 80 is open and running nginx 1.19.0 web server.

Impact:
Data transmitted over HTTP is not encrypted. Attackers may intercept sensitive information using Man-in-the-Middle attacks.

Recommendation:
Implement HTTPS using SSL/TLS certificate.

```
PORT   STATE SERVICE VERSION
80/tcp open  http    nginx 1.19.0
|_http-title: Home of Acunetix Art
```

🔍 Finding 2: Server Version Disclosure

Tool Used: Nmap
Risk Level: Low

Description:
The web server version (nginx 1.19.0) is publicly visible.

Impact:
Attackers can search for known vulnerabilities associated with this version.

Recommendation:
Disable server version disclosure in server configuration.

🔍 Finding 3: Cross-Site Scripting (Reflected)

Tool Used: OWASP ZAP
Risk Level: High

Description:
The application reflects user input without proper validation or encoding.

Impact:
Attackers can inject malicious scripts to steal session cookies or perform malicious actions on behalf of users.

Recommendation:
Implement proper input validation and output encoding mechanisms.

🔍 Finding 4: SQL Injection

Tool Used: OWASP ZAP
Risk Level: High

Description:
The application appears vulnerable to SQL Injection attacks.

Impact:
Attackers may access, modify, or delete sensitive database information.

Recommendation:
Use parameterized queries and prepared statements. Validate all user inputs.

🔍 Finding 5: Missing Security Headers

Tool Used: OWASP ZAP
Risk Level: Medium

Description:
Important security headers such as Content Security Policy (CSP) and Anti-Clickjacking headers are not properly configured.

Impact:
Increases risk of clickjacking and XSS attacks.

Recommendation:
Implement recommended HTTP security headers:

- Content-Security-Policy
- X-Frame-Options
- X-Content-Type-Options

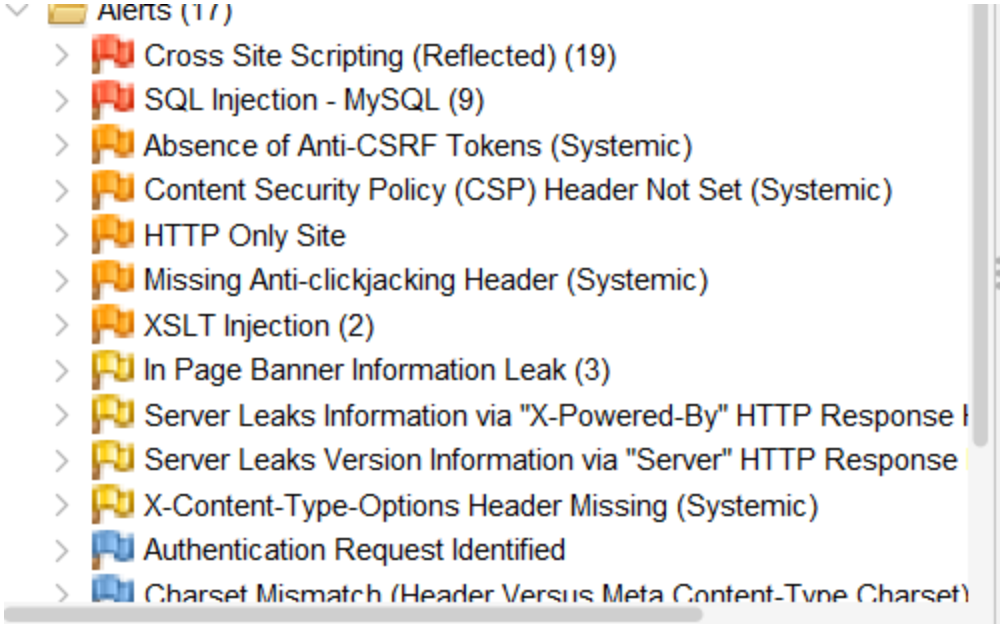
🔍 Finding 6: Server Information Disclosure

Tool Used: OWASP ZAP
Risk Level: Low

Description:
The server reveals technology details via HTTP response headers.

Impact:
Attackers can use this information to identify known vulnerabilities.

Recommendation:
Disable unnecessary header information exposure.



---

7. Risk Summary

Risk Level	Count
High	2
Medium	2
Low	2

---

8. Conclusion

The vulnerability assessment identified several critical and moderate security issues including Cross-Site Scripting and SQL Injection vulnerabilities.

Immediate remediation is recommended to prevent exploitation and protect user data.

Implementing proper input validation, HTTPS encryption, and secure configuration practices will significantly improve the security posture of the application.